CoverageProof | VAPT assessment

Assessment c9fd9c4c1044489890082ed42af894c0 | Snapshot 3d34dfd64bdc45ba9b2d30de72efb96f

Executive summary

B: admin surface unattempted

1 normalized issue candidates; 2 declared checks. Candidates are suspected until reviewed. An open TCP service is discovery, not a vulnerability. This report does not establish that any asset is secure.

Assessment methodology and rules of engagement

Coverage is limited to the explicitly declared checks. Literal-IP network boundaries and permitted ports are enforced. All runner actions need one-use approval. Redirects and environment proxies are disabled for the supported HTTP runner. Native findings-only exports cannot establish negative checks.

{
"name": "Owned HTTP experiment",
"revision": 1,
"networks": [
"127.0.0.1/32"
],
"ports": [
41553
],
"exclusions": [],
"authorization_reference": "Self-owned Python HTTP fixture; not organizer authorization",
"environment": "self-owned-development",
"allowed_paths": [
"/"
],
"excluded_paths": [],
"evidence_max_age_hours": 24
}

Tool execution and assets tested

6142d17b5b3d4123b14097669199b87a | http://127.0.0.1:41553/ | X-Content-Type-Options is absent or differs from nosniff | finding_supported

Execution 41eef1023be9475b8fcfdde24fe1ae04: completed; 2026-11-02T15:48:55.933818+00:00; One response recorded; no broader security conclusion.

d24fafda2f644854b9c33c9712dfa7b8 | http://127.0.0.1:41553/admin | X-Content-Type-Options is absent or differs from nosniff | condition_not_observed

Execution 25a49e169da24a5cad3021b44047cb53: completed; 2026-11-02T15:48:55.965002+00:00; One response recorded; no broader security conclusion.

Artifact 298b2f4339b04a6f953a9eac5889078c: http, source=live, ingested=2026-11-02T15:48:55.953162+00:00, SHA256=b557bdd3dabb867133092c1c733746fce2de62e52468e7b809534a87dcd53eeb

Artifact 4791b31eac8d41758267f1c2186f9a34: http, source=live, ingested=2026-11-02T15:48:55.975906+00:00, SHA256=3e862d940544de5d9cdc0ba11afe71b22587bdd042ddc253c3c6e14a58032c2c

Finding review summary

{"suspected; analyst review required": 1}

All candidates, including false-positive decisions, remain below for traceability. An accepted-for-report decision is analyst judgment, not proof of exploitation. New evidence makes earlier reviews outdated.

Severity distribution and prioritization

{"low": 1}

Ranking uses the highest supplied source severity, then attributed exposure, asset impact and analyst validation. Asset and finding identifier break ties. Missing inputs stay unknown. No numerical confidence, CVSS or combined risk score is invented. False-positive candidates are excluded from the active severity distribution but retained in the evidence record.

Detailed vulnerability findings, impact and remediation

1e7c23c85242 | Missing or unexpected X-Content-Type-Options

asset: http://127.0.0.1:41553/

issue_class: header:x-content-type-options

severity: low

cvss: None

confidence: direct response observation

status: suspected; analyst review required

impact: Not independently established; depends on affected asset and validation.

remediation: Set X-Content-Type-Options: nosniff on the affected response and verify content types.

Evidence status: source_reported; freshness: inspect_source_times; source tools: http

Same endpoint and issue condition; timing, response variants and scanner configuration can still explain differing observations. No majority vote or exploitability inference.

http | finding_supported | 2026-11-02T15:48:55.952502+00:00 | observation 0c8019ce5aad44519a4840b104e7b04e: GET http://127.0.0.1:41553/; HTTP 200; nosniff=False. Only this response and condition assessed; redirects not followed.

{"method": "Source severity first, then analyst-declared exposure, asset impact and validation. Asset/id break remaining ties. No numeric risk score.", "severity_reason": "Highest supplied finding severity is low; supplied values: ['low']. Source differences remain visible.", "exposure": "unknown", "asset_impact": "unknown", "exploitability": "not_assessed", "confidence": "Source confidence labels are retained without numerical conversion or cross-tool averaging.", "limitations": "Analyst context is an attributed assessment, not independent verification. A high source severity can still be a false positive."}

CVE/CWE: not independently established. References: native artifact and source pointers below.

{"observation": "0c8019ce5aad44519a4840b104e7b04e", "artifact": "298b2f4339b04a6f953a9eac5889078c", "source_ref": "HTTP response headers"}

Evidence and coverage limitations

http://127.0.0.1:41553/ | finding_supported

Collection freshness: current_window

0c8019ce5aad44519a4840b104e7b04e / 298b2f4339b04a6f953a9eac5889078c HTTP response headers: GET http://127.0.0.1:41553/; HTTP 200; nosniff=False. Only this response and condition assessed; redirects not followed.; observed=2026-11-02T15:48:55.952502+00:00

http://127.0.0.1:41553/admin | condition_not_observed

Collection freshness: current_window

c6758f42c47a498d8be16b3c45296fe7 / 4791b31eac8d41758267f1c2186f9a34 HTTP response headers: GET http://127.0.0.1:41553/admin; HTTP 200; nosniff=True. Only this response and condition assessed; redirects not followed.; observed=2026-11-02T15:48:55.975253+00:00

Assumptions, failures, approvals and timestamps

Analyst-supplied imports are not live executions or authenticated attestations. Schema-valid input alone does not establish origin. Scope revisions make earlier plans stale. Import timestamps are preserved, but timestamps outside the scope-defined evidence window are marked stale, and unknown or future timestamps remain explicit limitations. Organizer evaluation authorization must be supplied separately from the self-owned development scope.

Assessment created 2026-11-02T15:48:55.924614+00:00; report snapshot 2026-11-02T15:48:55.986740+00:00. Model reasoning and reviewer sign-off status must be verified before client delivery.

{"id": "d548e6cb80b9438cad61797161c199e1", "check_id": "6142d17b5b3d4123b14097669199b87a", "fingerprint": "cea24ce5692371766886b52cc6ac52a90b1ebc7937e11ab1c46b894de62ccc48", "actor": "Owned fixture experiment", "created": "2026-11-02T15:48:55.931485+00:00", "consumed": "2026-11-02T15:48:55.933798+00:00"}

{"id": "8961a966849d45d39ee3a07a4a37cdac", "check_id": "d24fafda2f644854b9c33c9712dfa7b8", "fingerprint": "5e9b706186777a56066e300e7594de296f48e6a5d62cea39f0a61ddcbfd01d90", "actor": "Owned fixture follow-up", "created": "2026-11-02T15:48:55.962192+00:00", "consumed": "2026-11-02T15:48:55.964975+00:00"}

2026-11-02T15:48:55.953243+00:00 execution_finished: {"attempt": "41eef1023be9475b8fcfdde24fe1ae04", "status": "completed", "detail": "One response recorded; no broader security conclusion."}

2026-11-02T15:48:55.958599+00:00 planning_decision: {"mode": "development", "explanation": "DETERMINISTIC DEVELOPMENT MODE. Rule-based planning only; no language model has interpreted the request. Live AI reasoning remains a submission blocker.", "checks": [{"action": {"check": "header-nosniff", "target": "http://127.0.0.1:41553/admin", "port": null, "scope_revision": 1}, "rationale": "Development rule: declared condition remains unattempted. This is an assessment gap, not evidence of a vulnerability. Collect a bounded receipt for this exact target.", "evidence_ids": ["0c8019ce5aad44519a4840b104e7b04e"], "alternatives": [{"tool": "nikto", "reason_not_chosen": "A server scan is broader than this one response-header question and its export does not prove a negative for this exact check."}, {"tool": "no_action", "reason_not_chosen": "Skipping the check would leave this declared assessment question unanswered."}], "drawback": "Only one HTTP response is examined. This does not establish behavior across other routes, users or times."}], "provider": "development"}

2026-11-02T15:48:55.975984+00:00 execution_finished: {"attempt": "25a49e169da24a5cad3021b44047cb53", "status": "completed", "detail": "One response recorded; no broader security conclusion."}